UniHR 產品介紹

> 本文件適合非技術背景的讀者閱讀，包含產品簡介、核心功能、所有頁面說明，以及開發歷程。

一、產品簡介

UniHR 是一套專為臺灣企業設計的 **AI 人資助理 SaaS 平台**。

員工只需用自然語言提問，系統便會同時搜尋「公司內部規章」與「臺灣勞動法規」，合併產出最佳解答，並標明來源出處。企業不需要自行建置 AI 基礎設施，開通帳號即可使用。

解決什麼問題？

傳統方式	UniHR 方式
HR 人員接聽大量重複諮詢	員工自助查詢，AI 即時回答
翻閱紙本或 PDF 規章	上傳文件後全文可搜尋
不清楚勞基法規定	同步查詢勞動法 AI 引擎
各公司自建 IT 系統	SaaS 多租戶，開箱即用

服務架構（雙層設計）

1. **Core 層（勞動法 AI 引擎）**：持續優化的臺灣勞動法問答知識庫，由平台統一維護。
2. **SaaS 層（本平台）**：每家企業擁有獨立空間，管理自己的帳號、文件、使用記錄與配額。

每次提問時，系統同時搜尋「您公司的規章」與「勞動法 Core」，合併回答。

二、核心功能

🏢 多租戶企業隔離

- 每家企業擁有完全獨立的資料空間，企業之間資料零交叉
- 可設定文件數量、每月查詢次數、儲存空間等配額上限
- 支援**白標品牌客製化**：上傳公司 Logo、設定主題色彩與企業名稱，打造專屬外觀

👥 帳號與角色管理

系統提供六個角色層級，依職責分配不同權限：

角色	說明
超級管理員（Superadmin）	平台級別管理，管理所有企業租戶
擁有者（Owner）	企業最高管理者，管理公司設定與訂閱
管理員（Admin）	管理員工帳號、部門、文件與用量
人資管理員（HR）	管理部門結構、上傳文件、查看 RAG 品質儀表板
員工（Employee）	一般使用者，可使用 AI 問答與查閱文件
檢視者（Viewer）	唯讀權限

- 支援 **Google / Microsoft 單一登入（SSO）**，以 Email 自動識別所屬企業
- 管理角色強制啟用**雙重驗證（MFA/TOTP）**，保護高權限操作
- 支援以邀請連結方式新增員工，無需手動建立帳號

📄 企業知識庫

- 上傳公司內規、HR 政策文件，系統自動處理並建立可搜尋的知識庫
- 支援 **23 種檔案格式**：PDF（文字型 / 掃描型）、Word（DOCX/DOC）、Excel、PowerPoint、CSV、圖片、HTML、Markdown、RTF、JSON、網頁 URL 等
- 文件上傳後自動評估解析品質（優/良/可/差/失敗），確保知識庫品質
- 可依部門分類管理文件

🤖 AI 問答

- 員工輸入問題，AI 即時搜尋知識庫並生成回答

- **打字機串流效果**：回答即時逐字顯示，不需等待
- **來源引用面板**：每個回答都附上引用來源，區分「公司政策」與「勞動法規」，含相似度評分
- **Markdown 格式渲染**：支援表格、清單、程式碼等結構化顯示
- **後續建議**：AI 自動生成相關追問，引導深入探索
- **對話歷史**：可搜尋過去的對話，並匯出為文字檔
- **回饋機制**：員工可對每個回答按讚 👍 或按爛 👎，協助持續優化

🔍 智慧檢索引擎

- 同時使用「語意理解」與「關鍵字比對」兩種方式搜尋，取長補短
- 中文分詞精準處理，支援「NT$850,000」等格式
- 當主要向量資料庫異常時，自動切換備用搜尋，確保服務不中斷

📊 用量統計與分析

- 每位員工與整體公司的 AI 查詢次數、Token 使用量一目了然
- 管理員可查看熱門問題、部門統計、每日趨勢
- 超過配額時自動告警

📋 稽核日誌（合規用途）

- 完整記錄每次問答：誰問了什麼、引用了哪些來源、AI 如何回答
- 記錄**不可竄改**：每筆資料計算數位指紋，資料庫層阻擋任何修改或刪除
- 預設保存 **7 年**，滿足企業合規需求

💳 訂閱與金流

- 彈性訂閱方案，可依需求升級或降級
- 支援**藍新金流（NewebPay）**與 **Stripe** 付款
- 完整帳單記錄，可匯出

🌐 自訂網域與多地區

- 企業可設定自有網域（如 `hr.yourcompany.com`），搭配 SSL 自動申請
- 支援 4 個部署區域（亞太/北美/歐洲/日本），滿足資料駐留合規要求（PDPA / GDPR / SOC 2 / APPI）

🔒 資訊安全

✅ 已實作

認證與 Session - 登入憑證存於 **HttpOnly + Secure + SameSite=Lax Cookie**，JavaScript 無法讀取，防範 XSS 竊取 - Refresh Token 路徑限縮至 `/api/v1/auth/refresh`，無法被其他端點竊用 - JWT 採雙 Token 設計：Access Token（30 分鐘）+ Refresh Token（含 jti 唯一碼，可即時撤銷） - 密碼以 **bcrypt** 雜湊，自動加鹽，抵抗彩虹表攻擊 - 密碼強度驗證：最少 8 字元、須含英文字母與數字、常見密碼黑名單 - **帳號鎖定**：連續 5 次登入失敗自動鎖定 15 分鐘 - 登入前強制完成 **Email 信箱驗證** - 支援 **TOTP 雙重驗證（MFA/TOTP）**，管理角色可啟用 - **Google / Microsoft SSO** 採 PKCE + HMAC-SHA256 state 簽名，redirect_uri 伺服器端白名單驗證

存取控制 - 六個角色層級 RBAC（superadmin / owner / admin / hr / employee / viewer） - FastAPI dependency 統一注入，每個端點均有權限守衛 - **PostgreSQL Row-Level Security（RLS）**：資料庫層強制租戶隔離，應用層與 DB 層雙重保護 - Admin 系統管理端點僅限白名單 IP / CIDR 存取

網路防護 - 三層速率限制（IP 層 200r/min、用戶層 60r/min、租戶層 300r/min），濫用自動封鎖 10 分鐘 - Nginx 層額外限流（Chat 20r/min、Auth 10r/min、一般 60r/min） - CORS 強制白名單，生產環境禁止萬用字元 `*` - **CSRF 雙重提交防護**（cookie + header 比對），Payment webhook 等路徑合理豁免 - **SSRF 攻擊封鎖**：外部 URL 呼叫前 DNS 解析驗證，封鎖 Private / Loopback / Link-local IP

HTTP 安全標頭（Nginx 層） - `Strict-Transport-Security`（HSTS，2 年，含 preload） - `X-Frame-Options: DENY`（防止 clickjacking） - `X-Content-Type-Options: nosniff` - `Content-Security-Policy` - `Referrer-Policy: strict-origin-when-cross-origin` - HTTP 強制重導向 HTTPS，TLS 1.2 / 1.3

檔案與內容安全 - 所有上傳文件均經 **ClamAV 病毒掃描**（fail-closed：掃描失敗則拒絕上傳） - **LLM Prompt Injection 護欄**：正則表達式過濾常見注入模式，output 同步過濾敏感內容

容器與基礎設施 - Docker 以**非 root 用戶（unihr）**執行，降低容器逃逸風險 - 多階段 build：編譯工具不進入 production image - 生產環境 DB port 不對外暴露

稽核與日誌 - 完整操作稽核日誌，每筆含 **SHA-256 數位指紋**，DB trigger 阻擋任何 UPDATE / DELETE - 保留 **7 年**，滿足合規要求

生產啟動驗證（13 項強制檢查） - 啟動時自動驗證：SECRET_KEY 強度、DB 密碼、預設帳密未使用、DB SSL 模式、ClamAV 啟用、Admin IP 白名單啟用、CORS 無萬用字元等，任一不符即阻擋服務啟動

⚠️ 已識別但尚未修補（待辦）

項目	風險等級	說明
MFA 未強制	高	`MFA_REQUIRED_FOR_PRIVILEGED` 預設關閉，生產啟動驗證未強制要求特權角色啟用 MFA
Redis 無密碼強制	高	生產 docker-compose 未以 `:?` 強制設定 Redis 密碼（DB 有，Redis 沒有）
CSP 含 `unsafe-inline`	中	Nginx gateway.conf 的 `script-src` 含 `'unsafe-inline'`，削弱 XSS 防護，應改用 nonce/hash
無自動化依賴漏洞掃描	中	缺乏 Dependabot / Snyk 等 SCA 工具，第三方套件漏洞無法自動告警
JWT 使用 HS256 對稱算法	中	多服務共用同一 SECRET_KEY；建議改用 RS256 非對稱算法
Domain 快取無過期時間	中	自訂域名記憶體快取無 TTL，域名撤銷後需重啟服務才生效
PostgreSQL SSL 未強制 verify-full	低	生產 SSL 模式設 `prefer`（可降級明文），應強制 `verify-full`
集中化日誌平台缺失	低	日誌只在容器內，無 Loki / ELK 集中收集，出事溯源困難
Nginx Admin IP 白名單為範例	低	`nginx/admin.conf` 的 IP 白名單設定為 commented-out 範例，實際只靠後端中間件
最低密碼長度 8 字元	低	NIST SP 800-63B 建議 12 字元以上

2026-03-23 安全評估得分：A- / 8.8 分

三、所有頁面

公開頁面（任何人皆可瀏覽）

頁面	說明
首頁	產品介紹，含功能亮點、FAQ、聯絡我們
定價方案	各方案功能對比與定價
登入	Email + 密碼登入，或 Google / Microsoft SSO
註冊	企業自助開通帳號
接受邀請	員工透過邀請連結加入企業
Email 驗證	信箱驗證跳轉頁
隱私政策	個資使用說明（PDPA 合規）
服務條款	平台使用規範

登入後功能頁面

所有員工可使用

頁面	功能說明
AI 問答（主頁）	輸入問題，AI 即時回答。支援打字機串流、來源面板、回饋按鈕、後續建議、搜尋歷史對話、匯出 Markdown
知識庫管理	拖放上傳文件、查看處理狀態、依部門篩選
我的用量	查看個人的 AI 查詢次數與 Token 使用量

管理員 / 擁有者專用

頁面	功能說明
用量統計	全公司的 Token 使用量、查詢次數、儲存容量圖表

頁面	功能說明
稽核日誌	操作記錄查詢、篩選、匯出
部門管理	樹狀層級部門結構，可新增、編輯、收合 *(人資管理員 HR 亦可存取)*
公司設定	企業基本資訊、SSO 設定
SSO 設定	設定 Google / Microsoft 企業單一登入
品牌設定	上傳 Logo、設定主題色彩、企業名稱 + 即時預覽效果
訂閱方案	查看目前方案、對比升級選項、確認升級
自訂網域	設定企業自有網域，引導 DNS 驗證
RAG 儀表板	AI 問答品質監控：對話量統計、回應延遲（P50/P95）、回饋分布、每日趨勢圖 *(人資管理員 HR 亦可存取)*
品質儀表板	文件解析品質分佈、知識庫檢索得分分佈、低品質文件警示
地區資訊	資料儲存地區設定、各地區合規資訊

平台管理後台（超級管理員專用，port 8080）

> 平台營運人員使用，管理所有企業租戶。

頁面	功能說明
登入	Superuser 專用登入頁
租戶管理總覽	所有企業清單、狀態、基本資訊管理
配額管理	調整各企業的文件數、查詢次數、Token 上限
收支總覽（PnL）	平台損益分析、各企業成本與收益明細
成本分析	平台整體成本趨勢、API 費用分析

四、開發計畫

本產品採用分階段迭代方式開發，共規劃 **13 個開發階段**，預計總開發時程約 **34 週**。

階段	主要內容	預估時程
Phase 1	核心基礎：多租戶架構、帳號認證、文件上傳管線、AI 問答基礎	Week 1–3
Phase 2	安全強化：Google/Microsoft SSO 登入、速率限制、API 版本管理、功能旗標	Week 4–5
Phase 3	管理功能：配額管理、用量分析、前端管理頁面	Week 6–7
Phase 3+	文件引擎升級：支援 19 種格式、進階混合搜尋（語意 + 關鍵字）	Week 8–9
Phase 4	生產化：前後台分離、CI/CD 自動部署、白標品牌、監控系統、微服務架構、多地區支援（22 項任務）	Week 10–13
Phase 5	使用者體驗全面審查：11 項 UX 修復（路由守衛、SSO 自動識別企業、權限統一、UI 細節優化）	Week 14–15
Phase 6	AI 引擎升級：LlamaParse 智慧解析、中文分詞（jieba）、HyDE 查詢擴展、更精準的 LLM 答案生成、重複內容去除	Week 16–18
Phase 7	對話體驗升級：串流打字機效果、Markdown 渲染、來源引用面板、回饋系統、RAG 品質儀表板、行動版響應式（15 項任務）	Week 19–21
Phase 8	生產安全加固：啟動前 13 項安全硬性檢查、一鍵密鑰生成工具、生產容器安全強化（15 項安全特性）	Week 22–23

階段	主要內容	預估時程
Phase 9	縱深防禦：Redis 熔斷保護、不可竄改稽核日誌、資料庫層 Row-Level Security、備份自動驗證、安全監控告警、壓力測試（7 項）	Week 24–25
Phase 10	資安全面強化：HttpOnly Cookie session（取代 localStorage）、CSRF 雙重驗證、SSRF 攻擊封鎖、SSO 安全白名單、管理角色強制 MFA（11 項）	Week 26–27
Phase 11	檢索引擎強化：向量儲存雙備援（Pinecone + PostgreSQL）、零品質向量過濾、BM25 快取優化、智慧解析策略調整	Week 28–29
Phase 12	AI 可觀測性：Langfuse 全鏈路追蹤（解析→嵌入→問答）、MCP Server（外部 AI 整合介面）	Week 30–31
Phase 13	品質儀表板、進度追蹤、品牌驗證、LLM 安全護欄（防止 Prompt 注入）、金流整合（藍新金流 + Stripe）、Email 服務	Week 32–34

各階段重要里程碑

```
Phase 1–3    基礎平台建立，可運行最小可行產品（MVP）

Phase 4–5    生產化與用戶體驗完善，準備正式上線

Phase 6–7    AI 問答品質大幅提升，對話體驗現代化

Phase 8–10   全面資安強化，目標通過安全評估（A 級）

Phase 11–13  檢索精準度、可觀測性、金流、品質儀表板完善
```

文件更新日期：2026-03-26